UNIVERSIDAD CAECE

Cámara Argentina de Comercio y Servicios

LICENCIATURA EN CIENCIA DE DATOS

SEGURIDAD INFORMÁTICA

GUIA DE LA UNIDAD III

Contenidista: Germán Ariel Paradisi

INDICE – Guía de la Unidad III

1. INTRODUCCIÓN AL ANÁLISIS DE VULNERABILIDADES....7
1.1 Vulnerabilidades físicas.... 7
1.2 Vulnerabilidades lógicas.... 7
2. TIPOS DE VULNERABILIDADES.... 8
2.1 Desbordamiento de buffer.... 8
2.2 Errores de configuración.... 9
2.3 Errores WEB....9
2.4 Errores de protocolo....10
2.5 Aprovechamiento de las vulnerabilidades....10
3. ESTÁNDARES PARA VALORAR VULNERABILIDADES....11
3.1 CVE | Common Vulnerabilities and Exposures.... 11
3.1.1 CVE Details.... 11
3.2 CWE | Common Weakness Enumeration....12
3.3 CAPEC | Common Attack Pattern Enumeration and Classification....12
3.4 Valoración de vulnerabilidades.... 13
3.4.1 ¿Qué es CVSS?....13
3.4.2 ¿Cómo se calcula el impacto con CVSS?....14
3.4.3 Beneficios de utilizar CVSS.... 15
4. DETECCIÓN DE VULNERABILIDADES....15
4.1 Herramientas para escanear vulnerabilidades.... 16
4.2 Establecimiento de las reglas del juego....17
4.3 Recolección de información.... 17
4.4 Tipos de pruebas de seguridad....18
4.4.1 Análisis interno....18
4.4.2 Análisis externo.... 19
4.4.3 Sondeo de red.... 19
4.4.4 Identificación de los servicios de sistemas....20
4.4.5 Búsqueda y verificación de vulnerabilidades.... 20
4.4.6 Testeo de aplicaciones de internet....20
4.4.7 Testeo de relaciones de confianza....20
4.4.8 Verificación de redes inalámbricas....21
4.5 Documentación e Informes.... 21
4.6 Ciclo de vulnerabilidades....21
4.6.1 Análisis de activos.... 21
4.6.2 Clasificar y priorizar riesgos....22
4.6.3 Probar parches y configuraciones.... 22
4.6.4 Aplicar parches y configuraciones....23
5. TIPOS DE ANÁLISIS DE VULNERABILIDADES.... 23
5.1 Escaneo de vulnerabilidades.... 24

5.1.1 Análisis de GAP....24

5.2 Evaluación de Vulnerabilidades....24
5.2.1 Aspectos involucrados en una Evaluación de Vulnerabilidades....25
5.3 Pruebas de penetración....25
5.3.1 Fase de reconocimiento....26
5.3.2 Fase de escaneo....26
5.3.3 Fase de enumeración....27
5.3.4 Fase de acceso....27
5.3.5 Fase de mantenimiento de acceso....28
5.4 Ejercicios de Red Team....28
5.5 Ejercicios de Purple Team....29
5.6 Emulaciones de adversarios....29
6. OWASP....30
6.1 OWASP TOP 10 DE 2021....30
6.1.1 Pérdida de control de acceso....30
6.1.2 Fallas criptográficas....30
6.1.3 Inyección....31
6.1.4 Diseño Inseguro....31
6.1.5 Configuración de seguridad incorrecta....31
6.1.6 Componentes vulnerables y desactualizados....31
6.1.7 Fallas de identificación y autenticación....32
6.1.8 Fallas en el Software y en la Integridad de los Datos....32
6.1.9 Fallas en el Registro y Monitoreo....32
6.1.10 Falsificación de Solicitudes del Lado del Servidor (SSRF)....32
7. OSINT: INTELIGENCIA DE FUENTES ABIERTAS....33
7.1 Investigación defensiva....33
7.2 Conceptos básicos....33
7.3 Por qué usar OSINT....34
7.4 Aplicación en ciberseguridad....34
7.5 OSINT ¿Legal o Ilegal?....34
7.6 Ciclo OSINT....35
7.7 Obtención de la información....35
7.7.1 Tipos de fuentes de información....36
7.7.2 Obtención de información....36
7.7.3 Herramientas de búsqueda: Dorks en buscadores....37

MAPA DE LA GUIA III: Seguridad ofensiva

OBJETIVOS

En esta Unidad esperamos que el estudiante pueda

- Comprender las diferencias entre las vulnerabilidades físicas y lógicas y su impacto en la seguridad de los sistemas informáticos.
- Identificar y describir diferentes tipos de vulnerabilidades, como desbordamiento de buffer, errores de configuración, errores web y errores de protocolo.
- Analizar los estándares utilizados para evaluar y clasificar vulnerabilidades, incluyendo CVE, CWE y CAPEC, y comprender su importancia en la gestión de riesgos.
- Explorar las herramientas disponibles para la detección de vulnerabilidades y aprender a establecer reglas y recopilar información relevante para su análisis.
- Conocer los distintos tipos de pruebas de seguridad, como análisis interno, análisis externo, sondeo de red y pruebas de aplicaciones web, y comprender su aplicación en la evaluación de vulnerabilidades.
- Dominar el ciclo de vida de las vulnerabilidades, desde el análisis y clasificación hasta la aplicación de parches y configuraciones para su mitigación.
- Explorar los diferentes enfoques de análisis de vulnerabilidades, incluyendo el escaneo, la evaluación, las pruebas de penetración y los ejercicios de Red Team y Purple Team.
- Comprender el concepto de OSINT (Inteligencia de Fuentes Abiertas), su aplicación en ciberseguridad y su importancia en la obtención de información para la defensa y protección de sistemas y redes informáticas

CONTENIDOS

1. **Introducción al análisis de vulnerabilidades**

   1.1 Diferencias entre vulnerabilidades físicas y lógicas.

   1.2 Importancia de identificar y abordar vulnerabilidades en sistemas informáticos.

2. **Tipos de vulnerabilidades**

   2.1 Distintos tipos de vulnerabilidades, como desbordamiento de buffer, errores de configuración, errores web y errores de protocolo.

   2.2 Aprovechamiento de las vulnerabilidades en sistemas y redes.

3. **Estándares para valorar vulnerabilidades**
   - 3.1 Estándares utilizados en la industria para evaluar y clasificar vulnerabilidades, como CVE, CWE y CAPEC.
   - 3.2 Uso de CVSS para calcular el impacto de las vulnerabilidades y comprender sus beneficios.
4. **Detección de vulnerabilidades**
   - 4.1 Herramientas disponibles para escanear vulnerabilidades y establecer reglas para su detección.
   - 4.2 Recolección de información y la importancia de documentar e informar sobre las vulnerabilidades detectadas.
5. **Tipos de análisis de vulnerabilidades**
   - 5.1 Tipos de análisis, incluyendo escaneo de vulnerabilidades, evaluación de vulnerabilidades y pruebas de penetración.
   - 5.2 Fases involucradas en pruebas de penetración, como reconocimiento, escaneo, enumeración, acceso y mantenimiento de acceso.
6. **OWASP**
   - 6.1 OWASP Top 10 de 2021, que identifica las principales vulnerabilidades en aplicaciones web.
   - 6.2 Diferentes tipos de vulnerabilidades, como pérdida de control de acceso, fallas criptográficas e inyecciones.
7. **OSINT: Inteligencia de fuentes abiertas**
   - 7.1 Conceptos básicos de OSINT y su aplicación en ciberseguridad.
   - 7.2 Legalidad de utilizar OSINT y aprender sobre el ciclo OSINT y las diferentes formas de obtener información mediante herramientas de búsqueda.

PALABRAS CLAVE

Vulnerabilidad – CVE – CVE – CAPEC – OSINT – CVSS – Red Team – Blue Team – Purple Team – OWASP – Riesgo – Pruebas de Penetración – Emulación de Adversarios

BIBLIOGRAFÍA Y MATERIALES DE REFERENCIA OBLIGATORIOS

Grubb, S. (2021). How Cybersecurity Really Works_ A Hands-On Guide for Total Beginners. Editorial No Starch Press

OWASP (2021) OWASP Top Ten. https://owasp.org/www-project-top-ten/

Romero, M; Figueroa, G; Vera, D; Álava, J; Parrales, G; Álava, C; Murilo, Á; Castillo,M. (2018). Introducción a la Seguridad Informática y el Análisis de Vulnerabilidades. Editorial Área de Innovación y Desarrollo,S.L.

BIBLIOGRAFÍA Y MATERIALES DE REFERENCIA OPTATIVOS

Kiser, Q. (2020). Ciberseguridad Una Simple Guía para Principiantes sobre Ciberseguridad, Redes Informáticas y Cómo Protegerse del Hacking en Forma de Phishing, Malware, Ransomware e Ingeniería Social. Editorial No Starch Press

1. INTRODUCCIÓN AL ANÁLISIS DE VULNERABILIDADES

En el contexto de la seguridad de la información, una vulnerabilidad puede entenderse como una brecha o punto débil presente en un sistema, aplicación o medida de seguridad que podría ser aprovechada por amenazas externas o internas. Esta vulnerabilidad puede ser explotada para comprometer la integridad, confidencialidad o disponibilidad de la información, generando así un riesgo significativo para la seguridad.

Existen dos categorías de vulnerabilidades:

1.1 Vulnerabilidades físicas

Las vulnerabilidades físicas representan una preocupación significativa en el ámbito de la seguridad de la información, ya que pueden afectar directamente la infraestructura física de una organización. Este tipo de vulnerabilidades incluye eventos como desastres naturales, como terremotos o inundaciones, que pueden causar daños materiales y afectar la disponibilidad de los servicios.

Por ejemplo, en áreas propensas a terremotos, la vulnerabilidad física se manifiesta en la posibilidad de interrupciones en el servicio debido a daños en la infraestructura. De manera similar, en zonas propensas a inundaciones, existe el riesgo de que el agua cause daños a equipos y sistemas, lo que también puede afectar la disponibilidad de los servicios.

Además de los desastres naturales, las vulnerabilidades físicas también pueden estar relacionadas con los controles de acceso inadecuados. Esto ocurre cuando la infraestructura crítica de una organización no cuenta con medidas adecuadas de control de acceso, lo que facilita el ingreso no autorizado de personas a áreas sensibles. Por ejemplo, si cualquier persona puede acceder a las instalaciones sin restricciones, existe el riesgo de que un individuo malintencionado pueda ingresar con dispositivos de almacenamiento USB y comprometer la seguridad de la red mediante la copia de información confidencial o la introducción de malware en los sistemas.

1.2 Vulnerabilidades lógicas

Las vulnerabilidades lógicas son aquellas que afectan directamente a la infraestructura y el funcionamiento operativo de los sistemas informáticos. Estas pueden clasificarse en diferentes categorías, entre las que se incluyen:

- **Vulnerabilidades de configuración**: Estas se refieren a las configuraciones incorrectas o inseguras en el sistema operativo, las aplicaciones del servidor o los firewalls. Esto puede incluir configuraciones por defecto que no han sido modificadas para adaptarse a las necesidades específicas de seguridad de la organización, así como configuraciones mal gestionadas en la infraestructura perimetral.

- **Vulnerabilidades de actualización**: Muchas empresas no mantienen sus sistemas actualizados con los últimos parches de seguridad, lo que deja a sus sistemas expuestos a vulnerabilidades conocidas. Por ejemplo, el fin del soporte para sistemas como Windows XP ha dejado a muchas organizaciones con sistemas obsoletos y vulnerables que ya no reciben actualizaciones de seguridad.
- **Vulnerabilidades de desarrollo**: Estas incluyen errores de programación que pueden ser explotados por atacantes para comprometer la seguridad de una aplicación. Ejemplos de este tipo de vulnerabilidades son las inyecciones de código SQL y los ataques de Cross Site Scripting (XSS). La falta de validación adecuada de los datos de entrada también puede conducir a vulnerabilidades de este tipo.

Es importante destacar que cada tipo de vulnerabilidad lógica puede ser auditado y evaluado mediante diferentes metodologías de pruebas de penetración y cumplimiento. Los escáneres de vulnerabilidades utilizan diversas escalas y técnicas de análisis para identificar y mitigar estos riesgos, adaptándose a las necesidades específicas de seguridad de cada entorno, ya sea una red interna o una aplicación web. La elección del escáner adecuado depende del contexto y los objetivos de seguridad de la organización.

2. TIPOS DE VULNERABILIDADES

Existen algunos tipos de vulnerabilidades que son mecanismos aprovechados por los atacantes para infectar una red o robar información entre los cuales se puede mencionar a los siguientes tipos:

2.1 Desbordamiento de buffer

El desbordamiento de búfer, conocido en inglés como *Buffer Overflow*, es una vulnerabilidad común en la programación donde un programa no controla adecuadamente el espacio de memoria asignado para un búfer, lo que permite que un atacante sobreescriba áreas de memoria adyacentes con su propio código. Esto puede conducir a la ejecución de ese código antes que otras tareas previstas.

Por ejemplo, este tipo de vulnerabilidad suele ser aprovechado mediante payloads, que son datos diseñados específicamente para explotar una vulnerabilidad, o en el caso de backdoors o puertas traseras que se inyectan en la memoria RAM con cierta cantidad de código malicioso, el cual puede ejecutarse antes de que el sistema operativo o algunos archivos del sistema se carguen normalmente. Es esencial para los programadores implementar medidas de seguridad adecuadas, como la validación de entradas y la gestión correcta de la memoria, para prevenir este tipo de ataques.

2.2 Errores de configuración

Otra de las principales vulnerabilidades son los errores de configuración, los cuales abarcan desde contraseñas predeterminadas o débiles hasta usuarios con privilegios excesivos y la utilización de protocolos de encriptación obsoletos. Es común que muchas organizaciones descuiden aspectos básicos de seguridad, como la configuración de contraseñas predeterminadas, lo que puede facilitar el acceso no autorizado a sistemas y datos sensibles.

Por ejemplo, el uso de contraseñas predeterminadas o débiles representa un riesgo significativo, ya que un atacante puede aprovechar fácilmente estas debilidades para obtener acceso no autorizado. Además, la utilización de protocolos de encriptación obsoletos o inseguros puede exponer las comunicaciones a riesgos de interceptación y manipulación por parte de personas no autorizadas.

Un caso particularmente preocupante es el uso de sistemas de encriptación web vulnerables, que pueden ser comprometidos en cuestión de segundos utilizando herramientas fácilmente disponibles, como aplicaciones de teléfonos celulares o laptops. Del mismo modo, los protocolos de SSH sin parches o actualizaciones pueden dejar expuestos sistemas a ataques y explotaciones.

Los errores de configuración también pueden manifestarse en la falta de actualizaciones de seguridad, lo que deja sistemas vulnerables a las últimas amenazas y vulnerabilidades conocidas. Por ejemplo, si se descuida la actualización de software y parches, un sistema puede quedar expuesto a ataques que ya han sido mitigados por los fabricantes de software.

2.3 Errores WEB

Otro conjunto importante de vulnerabilidades se encuentra en el ámbito web, donde los errores de validación de entrada, scripts inseguros y configuraciones incorrectas de aplicaciones web pueden abrir la puerta a diversos tipos de ataques, como el *Cross-Site Scripting* (XSS) o la inyección SQL (*SQL Injection*). Estos errores proporcionan a los atacantes la oportunidad de comprometer la seguridad de un sitio web y acceder a información confidencial.

La inyección SQL es uno de los ataques más comunes y peligrosos en la actualidad. En este tipo de ataque, los hackers aprovechan las vulnerabilidades en la entrada de datos para insertar comandos SQL maliciosos en las consultas a la base de datos. Esto les permite acceder, modificar o eliminar datos almacenados en la base de datos, incluidos nombres de usuario, contraseñas u otra información confidencial.

Por otro lado, los ataques de *Cross-Site Scripting* (XSS) tienen como objetivo insertar scripts maliciosos en páginas web visitadas por otros usuarios. Estos scripts pueden ejecutarse en el navegador de la víctima, lo que permite a los atacantes robar cookies de sesión, redirigir a los usuarios a sitios falsos o incluso tomar el control total de la sesión de la víctima.

Es fundamental para los desarrolladores y administradores de sistemas identificar y mitigar estas vulnerabilidades mediante prácticas de codificación seguras, auditorías regulares de seguridad y la implementación de medidas de protección como firewalls de aplicaciones web y filtros de entrada de datos. Además, la conciencia y la capacitación sobre seguridad informática son clave para prevenir y responder eficazmente a estos tipos de ataques.

2.4 Errores de protocolo

Por último, es importante mencionar las vulnerabilidades asociadas a los protocolos de comunicación. Muchos de estos protocolos fueron diseñados sin considerar adecuadamente la seguridad, y el crecimiento exponencial de Internet ha expuesto aún más estas debilidades.

Entre los protocolos vulnerables se encuentra el HTTP, que carece de mecanismos de encriptación para proteger la integridad y la confidencialidad de los datos intercambiados. Aunque es adecuado para la navegación web común, resulta insuficiente para transacciones sensibles como las bancarias, donde se requiere un nivel más alto de seguridad. En tales casos, se hace necesario implementar medidas adicionales como certificados SSL o TLS para garantizar una comunicación segura y protegida.

El principal desafío radica en definir un marco de seguridad sólido que aborde estas vulnerabilidades inherentes a los protocolos. Por ejemplo, es fundamental implementar controles de seguridad robustos en los sistemas web para mitigar posibles ataques y proteger la información confidencial de los usuarios.

2.5 Aprovechamiento de las vulnerabilidades

Por lo general, las vulnerabilidades se aprovechan de dos formas distintas:

- **Aprovechamiento Remoto**: En este caso, un atacante utiliza una computadora para analizar y atacar un servidor específico con el objetivo de vulnerarlo. Si el atacante logra obtener acceso no autorizado al sistema, se considera que ha tenido éxito en su explotación remota.
- **Ingeniería Social**: Aquí, el atacante recurre a la ayuda de individuos dentro de la organización para obtener acceso no autorizado. Esta táctica implica persuadir a una persona interna para que facilite el acceso a información confidencial o sistemas críticos.

Además, existen otras formas de ataques directos. Por ejemplo, en el caso del aprovechamiento remoto, el atacante identifica un software o servicio con un puerto abierto y vulnerable a través de Internet. Por otro lado, la ingeniería social implica engañar a un usuario para que ejecute acciones no deseadas, como abrir un archivo infectado o proporcionar información sensible. En ambos casos, el objetivo es explotar una vulnerabilidad en el sistema para obtener acceso no autorizado o comprometer la seguridad de la información.

3. ESTÁNDARES PARA VALORAR VULNERABILIDADES

Para estandarizar la comunicación sobre vulnerabilidades y facilitar su identificación y manejo, existen diversos estándares reconocidos en la industria. Entre estos estándares se encuentran el CVE, el CWE y el CAPEC.

Al utilizar estos estándares, los expertos en seguridad informática pueden comunicarse de manera más efectiva, compartir información sobre amenazas y vulnerabilidades, y colaborar en la implementación de medidas de seguridad más sólidas y eficientes. Esto ayuda a fortalecer la postura de seguridad de las organizaciones y a proteger sus activos de posibles ataques cibernéticos.

3.1 CVE | Common Vulnerabilities and Exposures

El CVE (*Common Vulnerabilities and Exposures*) es un sistema que ofrece una lista estandarizada de identificadores para las vulnerabilidades de seguridad cibernética conocidas públicamente. Estos identificadores, denominados "Registros CVE", son asignados por las Autoridades de Numeración CVE a nivel mundial. Su propósito es facilitar la identificación y referencia de vulnerabilidades, tanto por parte de individuos como de productos, con el fin de mejorar la seguridad y permitir el intercambio automático de datos entre sistemas y herramientas de seguridad.

El formato de un registro CVE sigue la estructura CVE-YYYY-NNNN, donde YYYY representa el año en que se descubrió la vulnerabilidad y NNNN es un número de identificación único. De esta manera, cada CVE sirve como un identificador específico para una vulnerabilidad particular. Por ejemplo, la vulnerabilidad conocida como #Log4Shell se identifica con el código CVE-2021- 44228.

3.1.1 CVE Details

CVE Details es una plataforma en línea que ofrece una extensa base de datos junto con una interfaz gráfica intuitiva para su consulta. Esta plataforma recopila una gran cantidad de información sobre vulnerabilidades comunes que han sido divulgadas públicamente, y organiza estos datos de diversas maneras para facilitar su acceso y comprensión.

En CVE Details, los usuarios tienen la capacidad de buscar vulnerabilidades según diferentes criterios, como el proveedor del software, el producto afectado, la fecha de divulgación y el tipo de fallo. Además, la plataforma proporciona una visión general de las vulnerabilidades más recientes, así como su puntuación en términos de gravedad y riesgo asociado.

Esta herramienta resulta invaluable para profesionales de la seguridad informática, ya que les permite mantenerse al tanto de las últimas vulnerabilidades descubiertas, evaluar su impacto potencial y tomar medidas proactivas para mitigar los riesgos en sus sistemas y redes. La capacidad de búsqueda y filtrado de CVE Details facilita la identificación de vulnerabilidades relevantes para un entorno específico, lo que permite una respuesta rápida y eficaz ante posibles amenazas.

Para conocer más sobre ***CVE Details***, puede acceder al link disponible dentro del aula virtual.

3.2 CWE | Common Weakness Enumeration

CWE (*Common Weakness Enumeration*) es un catálogo exhaustivo de debilidades comunes en el software y hardware de seguridad. Su propósito es actuar como un lenguaje universal que facilita la comunicación entre profesionales de la seguridad informática, proporcionando un marco estándar para la identificación, mitigación y prevención de vulnerabilidades.

A diferencia del CVE, que se centra en enumerar vulnerabilidades específicas, el CWE aborda categorías generales de debilidades que pueden manifestarse de diversas formas en diferentes sistemas y aplicaciones. En esencia, el CVE puede considerarse como una instancia o ejemplo particular de una debilidad identificada en el CWE.

El CWE proporciona un enfoque más holístico al abordar las raíces fundamentales de las vulnerabilidades, lo que permite a los profesionales de la seguridad informática comprender mejor los patrones subyacentes y tomar medidas preventivas más efectivas. Actúa como una herramienta crucial para el análisis de riesgos y la planificación de seguridad, ya que ayuda a priorizar la mitigación de debilidades que pueden afectar a múltiples sistemas y aplicaciones.

3.3 CAPEC | Common Attack Pattern Enumeration and Classification

CAPEC (*Common Attack Pattern Enumeration and Classification*) es una valiosa herramienta en el campo de la seguridad informática. Se presenta como un detallado diccionario y sistema de clasificación que documenta y organiza los diferentes patrones de

ataques conocidos. Este recurso no solo sirve como una guía para analistas, desarrolladores, probadores y educadores, sino que también contribuye significativamente a la comprensión colectiva de la comunidad sobre las tácticas utilizadas por los adversarios cibernéticos.

Al proporcionar una taxonomía estructurada de los patrones de ataque, CAPEC facilita el análisis y la identificación de posibles amenazas, así como el diseño de estrategias de defensa más efectivas. Además, ayuda a fortalecer las defensas al permitir que los profesionales de la seguridad comprendan mejor las motivaciones y métodos de los atacantes, lo que a su vez facilita la creación de contramedidas más específicas y adaptadas a las amenazas reales. En resumen, CAPEC desempeña un papel fundamental en la mejora continua de la seguridad cibernética al proporcionar un marco común para la comprensión y mitigación de los riesgos de seguridad.

3.4 Valoración de vulnerabilidades

En el ámbito de la seguridad informática, la gestión de riesgos juega un papel fundamental en la protección de sistemas y datos sensibles. Una de las prácticas más comunes es la identificación y evaluación de vulnerabilidades en software y hardware, con el fin de anticipar y prevenir posibles incidentes no deseados.

En un entorno donde los riesgos son cambiantes y los recursos limitados, resulta crucial priorizar las acciones de seguridad una vez identificadas las vulnerabilidades. Sin embargo, la dificultad radica en establecer criterios claros para convertir los datos en información útil y aplicable.

Para abordar este desafío, muchas organizaciones y empresas especializadas en seguridad han adoptado el *Common Vulnerability Score System* (CVSS). Este sistema proporciona una escala y un conjunto de criterios estandarizados para evaluar el impacto y la gravedad de las vulnerabilidades. Al asignar una puntuación objetiva a cada vulnerabilidad, el CVSS ayuda a las organizaciones a priorizar sus esfuerzos de seguridad y a tomar decisiones informadas sobre la asignación de recursos para mitigar los riesgos identificados. En resumen, el CVSS se ha convertido en una herramienta invaluable para la gestión proactiva de vulnerabilidades en el panorama de la seguridad informática.).

3.4.1 ¿Qué es CVSS?

El *Common Vulnerability Scoring System* (CVSS) es una herramienta vital en la gestión de la seguridad de la información. Se trata de un sistema de puntuación diseñado para proporcionar una evaluación estandarizada del impacto de las vulnerabilidades en las tecnologías de la información. Su objetivo es cuantificar la gravedad de las vulnerabilidades identificadas, lo que permite a las organizaciones priorizar sus esfuerzos de seguridad de manera efectiva.

El CVSS, que está bajo la supervisión del *Forum of Incident Response and Security Teams* (FIRST), se ha convertido en un estándar ampliamente utilizado y reconocido en la industria de la seguridad informática. Su naturaleza abierta permite su libre utilización por parte de cualquier entidad interesada en evaluar y mitigar riesgos de seguridad.

Es común encontrar referencias al CVSS en bases de datos de vulnerabilidades públicamente conocidas, como el CVE. Esta integración facilita a los profesionales de seguridad acceder a información detallada sobre las vulnerabilidades y tomar medidas adecuadas para proteger sus sistemas y datos frente a posibles ataques. En resumen, el CVSS desempeña un papel crucial en la mejora de la postura de seguridad de las organizaciones al proporcionar un marco objetivo y coherente para la evaluación de vulnerabilidades.

3.4.2 ¿Cómo se calcula el impacto con CVSS?

El *Common Vulnerability Scoring System* (CVSS) es una herramienta esencial en el ámbito de la seguridad informática para evaluar el impacto de las vulnerabilidades. Utiliza una escala del 0 al 10 para determinar la gravedad de una vulnerabilidad, donde los puntajes entre 0.0 y 3.9 se consideran de baja severidad, entre 4.0 y 6.9 de severidad media, y de 7.0 a 10.0 de severidad alta.

Para calcular este puntaje, el CVSS utiliza tres grupos de métricas: *base, temporal y de entorno*. Las **métricas base** describen las características intrínsecas de la vulnerabilidad, como el vector de acceso, la complejidad de acceso y la autenticación. Estas métricas determinan cómo se puede acceder a la vulnerabilidad y si se pueden cumplir las condiciones para explotarla. La severidad de estas métricas mide el impacto directo en la confidencialidad, integridad y disponibilidad de los activos de TI.

Las **métricas temporales** consideran los cambios en el tiempo de una vulnerabilidad, como la confirmación de detalles técnicos, el nivel de remediación y el nivel de confianza en el reporte. Estas métricas son opcionales y pueden omitirse si no son relevantes.

Por último, las **métricas de entorno** se centran en las características específicas del entorno del usuario, como el daño potencial colateral y los requisitos de confidencialidad, integridad y disponibilidad. También son opcionales y proporcionan información contextual para evaluar el riesgo en un entorno particular.

La ecuación CVSS calcula la puntuación y genera un vector de texto que comunica cómo se generó cada puntuación de vulnerabilidad. Este vector se muestra junto con la calificación de la vulnerabilidad para proporcionar una representación clara y detallada de la misma.

Es posible utilizar los grupos de entorno y temporal para proporcionar información contextual que refleje el riesgo de un ambiente específico, lo que permite tomar decisiones más informadas cuando se trata de mitigar los riesgos derivados de las vulnerabilidades. Para poner en práctica el método que se ha descrito, los usuarios pueden hacer uso la calculadora CVSS.

Para conocer más sobre la ***Calculadora CVSS***, puede acceder al link disponible dentro del aula virtual.

3.4.3 Beneficios de utilizar CVSS

El método definido por el CVSS ofrece diversas ventajas significativas en el ámbito de la seguridad informática. Una de las principales ventajas radica en la estandarización de las puntuaciones de vulnerabilidad, lo que permite establecer criterios coherentes para la gestión de riesgos. Esto facilita la comparación y priorización de vulnerabilidades en un entorno dado.

Además, al utilizar un marco abierto, CVSS proporciona información detallada sobre las características específicas de cada vulnerabilidad, lo que contribuye a una comprensión más profunda de su naturaleza y potencial impacto. Esta transparencia permite a los usuarios tomar decisiones fundamentadas sobre las medidas de seguridad que deben implementarse.

Otra ventaja importante es que al calcular la puntuación de una vulnerabilidad, esta se convierte en un indicador representativo del riesgo para una organización en particular. Esto permite una priorización consciente de las acciones de mitigación, enfocándose en las vulnerabilidades que presentan el mayor riesgo para el entorno de TI de la organización.

CVSS proporciona una metodología robusta y transparente para evaluar y gestionar las vulnerabilidades de manera efectiva, lo que permite a las organizaciones tomar decisiones informadas sobre cómo proteger sus activos de manera más eficiente.

4. DETECCIÓN DE VULNERABILIDADES

Detectar vulnerabilidades en un sistema es fundamental para garantizar su seguridad. Existen varias formas de hacerlo, entre las que se incluyen:

- **Escaneo de Vulnerabilidades**: Se utilizan herramientas especializadas, como Nikto, Nessus o Nmap, para identificar fallos en los servidores y servicios. Estas herramientas automatizadas exploran un rango de direcciones IP y realizan un análisis exhaustivo en busca de posibles vulnerabilidades. Esta forma de detección es rápida y eficiente, pero no siempre detecta todas las vulnerabilidades existentes.

- **Análisis Manual**: Aunque los escáneres de vulnerabilidades automatizados son útiles, es esencial complementarlos con análisis manuales. Los análisis manuales permiten una comprensión más profunda del sistema y pueden revelar vulnerabilidades que las herramientas automáticas pueden pasar por alto. Este enfoque garantiza una cobertura más completa y precisa en la detección de vulnerabilidades.
- **Consulta de Información**: También es posible utilizar técnicas de búsqueda de información en la red, como el "Google hacking", para encontrar información relevante que pueda revelar vulnerabilidades. Esta técnica implica buscar en la web información que pueda ser útil para identificar posibles vulnerabilidades en los servicios y sistemas de la organización.

Es importante combinar estas diferentes formas de detección de vulnerabilidades para obtener una evaluación completa y precisa de la seguridad del sistema. Los análisis automáticos proporcionan una primera capa de detección, mientras que los análisis manuales y la consulta de información complementan esta labor al revelar vulnerabilidades más sutiles y difíciles de detectar automáticamente.

4.1 Herramientas para escanear vulnerabilidades

En el ámbito de la seguridad informática, existe una amplia variedad de escáneres de vulnerabilidades disponibles, algunos de los cuales son de pago mientras que otros son gratuitos. Uno de los destacados es **Acunetix**, reconocido por su eficacia en la detección y explotación de vulnerabilidades en aplicaciones web. Este escáner no solo identifica posibles fallos de seguridad, sino que también ofrece la capacidad de verificar su explotación real. Además, herramientas como **netsparker** y **ProxyStrike** son útiles para detectar vulnerabilidades, con **netsparker** siendo una opción de pago y **ProxyStrike** disponible de forma gratuita, especializado en la detección de inyecciones de SQL y *Cross Site Scripting*.

Por otro lado, los escáneres dedicados a sistemas de gestión de contenido (CMS) son cada vez más comunes debido al creciente número de vulnerabilidades conocidas en estas plataformas. Estos escáneres se enfocan en identificar riesgos específicos relacionados con inyecciones SQL, gestión de administradores, entre otros aspectos.

Para evaluar la seguridad de los sistemas operativos, herramientas como **Nessus** y **Nexpose** son ampliamente utilizadas. **Nessus**, por ejemplo, es altamente versátil y puede integrarse incluso con sistemas operativos móviles como Android, permitiendo escanear redes desde un dispositivo móvil y gestionar los resultados de manera eficiente. Por su parte, **Nexpose**, vinculado a la familia **Metasploit**, ofrece la posibilidad de exportar resultados a herramientas como **Metasploit Pro o Express**, facilitando la creación de vectores de ataque específicos.

Además, herramientas como **LanGuard** y **OpenVAS** permiten realizar escaneos sin necesidad de credenciales o con credenciales de administrador. Estas herramientas no solo detectan vulnerabilidades, sino que también evalúan políticas de seguridad y procedimientos de gestión de equipos durante pruebas de penetración.

Estos escáneres operan mediante la actualización de firmas que validan las vulnerabilidades conocidas. Cuando se identifica una vulnerabilidad relevante, las firmas correspondientes se desarrollan y se actualizan en los escáneres, lo que garantiza una detección actualizada y precisa de posibles riesgos de seguridad.

4.2 Establecimiento de las reglas del juego

Otro aspecto fundamental antes de iniciar la detección de vulnerabilidades es establecer las reglas del juego, es decir, **definir claramente las tareas a realizar**, los límites a respetar y los permisos y obligaciones que deben cumplirse. Es importante tener en cuenta que la organización objeto del análisis puede no estar interesada en interrumpir sus servicios, especialmente si se trata de un ataque de denegación de servicio exitoso por parte del analista. En caso de que se presente esta situación, el experto debe ser capaz de identificar las vulnerabilidades sin afectar significativamente la operatividad de la red.

Durante el análisis, es crucial mantener informada a la menor cantidad de personas posible, con el objetivo de evitar cambios en el comportamiento de los usuarios que puedan influir en los resultados. Si los usuarios son conscientes del análisis, es probable que modifiquen sus prácticas inseguras por temor a represalias, lo cual podría alterar el panorama real de seguridad de la red y afectar la efectividad del análisis.

4.3 Recolección de información

La recolección de información es un aspecto crucial para la detección de vulnerabilidades. Se emplean diversos métodos de escaneo para llevar a cabo esta tarea, entre los cuales se destacan:

- **Caja Blanca**: Este método de escaneo **proporciona una visión completa de la red** y acceso a todos los equipos como súper usuario. En este enfoque, se actúa como un usuario legítimo dentro de la red, con la capacidad de utilizar los servicios de diversas formas. Con mayor detalle, se utilizan usuarios con privilegios específicos para acceder a los servicios, productos y software que se desean auditar. Se verifica si es posible realizar acciones adicionales basadas en los privilegios concedidos.
- **Caja Negra**: En este método de escaneo, se proporciona **información limitada de acceso a la red o al sistema**. Los analistas reciben únicamente información de acceso, como una dirección IP o el nombre de una empresa. A partir de esta información limitada, se busca recabar la mayor cantidad de datos posible sobre la dirección IP y otros equipos dentro del rango asociado. En este caso, no se realiza ninguna acción, simplemente se detectan y documentan las vulnerabilidades.
- **Caja Gris**: Además de los métodos de escaneo de caja blanca y caja negra, existe también el enfoque de caja gris. En este método, los analistas tienen **acceso parcial a la red o al sistema**, lo que significa que cuentan con información limitada pero no tan restringida como en la caja negra. Este enfoque combina aspectos de ambos métodos, permitiendo a los analistas realizar ciertas acciones y obtener cierta información privilegiada, pero sin tener una visión completa de la red o los sistemas involucrados. La caja gris ofrece

un equilibrio entre la profundidad de la información disponible y la capacidad de acción de los analistas, lo que puede ser útil en ciertos escenarios de análisis de vulnerabilidades.

La recolección de información es el punto de partida para cualquier análisis de vulnerabilidades, ya sea de tipo caja blanca o caja negra. En un análisis de caja blanca, se busca obtener una amplia gama de datos, como direcciones de servidores, nombres de usuarios, contraseñas, detalles sobre los servicios ofrecidos, esquemas de red, topologías de red y niveles de privilegios. Por otro lado, en un análisis de caja negra, se pueden obtener direcciones IP, nombres de dominio, direcciones de correo electrónico, entre otros.

Una técnica comúnmente utilizada en la recolección de información es la inteligencia de fuentes abiertas (**OSINT**), que implica recopilar datos de fuentes públicas disponibles en Internet. Esta información recabada proporciona una base sólida para el análisis de vulnerabilidades y ayuda a identificar posibles puntos de entrada para un atacante.

4.4 Tipos de pruebas de seguridad

Una vez que se recopila esta información se procede a realizar algunas de las siguientes pruebas que se muestran a continuación:

4.4.1 Análisis interno

Antes de proseguir con el análisis de vulnerabilidades, es fundamental realizar varios tipos de pruebas. Una de ellas es el análisis interno, el cual tiene como objetivo demostrar hasta dónde pueden llegar los privilegios de un usuario típico dentro de la organización. Para llevar a cabo este tipo de prueba, la organización debe proporcionar una computadora con las credenciales de acceso normales de un usuario específico.

El análisis interno consta típicamente de varias pruebas, entre las cuales se incluyen:

- **Revisión de la privacidad**: En esta prueba, el analista se enfoca en cómo se maneja desde el punto de vista ético y legal el almacenamiento, transmisión y control de la información utilizada por los usuarios y empleados en su día a día.
- **Pruebas de medidas de contingencia**: Se verifica la efectividad de las medidas de contingencia implementadas para detectar intentos de acceso no autorizado o proteger recursos críticos, así como la cantidad mínima de recursos necesarios para su funcionamiento.
- **Descifrado de contraseñas**: Se evalúa la robustez de las contraseñas mediante el uso de herramientas automáticas de recuperación de contraseñas, lo que revela contraseñas débiles o algoritmos criptográficos mal implementados.
- **Evaluación de políticas de seguridad**: Se analizan las políticas de seguridad para garantizar su coherencia con los objetivos del negocio de la organización y su alineación con las tecnologías utilizadas, evitando contradicciones que puedan comprometer la seguridad. Es esencial asegurar que las políticas de seguridad sean beneficiosas y prácticas para la organización en lugar de imponer restricciones innecesarias que puedan obstaculizar la operación del negocio.

4.4.2 Análisis externo

El análisis externo es una etapa crucial en la evaluación de la seguridad de una organización, ya que busca identificar y aprovechar posibles vulnerabilidades desde fuera de la red interna. Este tipo de prueba tiene como objetivo principal obtener acceso remoto a los servidores de la organización y obtener privilegios o permisos que no deberían estar disponibles.

El proceso de análisis externo puede comenzar con técnicas de **ingeniería social**, donde se intenta obtener información sensible de la organización a través de la manipulación psicológica de individuos clave. Los pasos típicos de este tipo de análisis incluyen:

- **Revisión de la inteligencia competitiva**: Se recopila información sobre la organización a partir de fuentes públicas en Internet, como redes sociales, sitios web y bases de datos disponibles en línea.
- **Revisión de la privacidad**: Se evalúa cómo se maneja, desde una perspectiva legal y ética, el almacenamiento, la transmisión y el control de los datos sensibles de los clientes. Por ejemplo, se investiga si existen vulnerabilidades que puedan comprometer la privacidad de los datos y cómo se gestionan las medidas de seguridad para proteger la información confidencial.
- **Análisis de solicitudes**: Se utilizan métodos para obtener privilegios de acceso a la organización y sus activos, a través de interacciones con el personal de entrada mediante comunicaciones como teléfono, correo electrónico o chat. Este enfoque puede implicar solicitudes fraudulentas o engañosas para obtener información confidencial.
- **Análisis de ingeniería social**: Se busca manipular a los empleados u otros miembros de la organización para que realicen acciones que faciliten el acceso no autorizado. Esto puede incluir la instalación de software malicioso a través de engaños o la creación de sesiones de usuario desde el exterior utilizando información obtenida de manera fraudulenta.

Es importante realizar un análisis externo de manera ética y dentro de los límites legales, evitando cualquier actividad que pueda ser considerada como intrusión no autorizada. El objetivo es identificar y mitigar las vulnerabilidades de seguridad antes de que puedan ser explotadas por individuos malintencionados.

4.4.3 Sondeo de red

El sondeo de red es una fase inicial crucial en el proceso de evaluación de seguridad de sistemas. Su propósito es **recopilar información preliminar** sobre los sistemas que serán objeto de análisis. Durante esta etapa, se examinan diversos elementos como nombres de dominio, servidores, direcciones IP, mapas de red, información del proveedor de servicios de Internet (ISP), propietarios de sistemas y servicios en funcionamiento. Esta recopilación de datos proporciona una visión general de la infraestructura de red y ayuda a identificar posibles puntos de entrada para futuros análisis de vulnerabilidades y pruebas de seguridad.

4.4.4 Identificación de los servicios de sistemas

Durante esta fase de evaluación, se procede a enumerar los servicios de Internet activos o accesibles en el sistema objetivo. Esto implica atravesar el *firewall*, si es necesario, para descubrir más máquinas activas en la red. Posteriormente, se lleva a cabo un análisis de las aplicaciones que están escuchando en esos servicios. Una vez identificados los servicios, el siguiente paso es la identificación del sistema, con el fin de obtener respuestas que revelen el sistema operativo y su versión.

Esto se logra mediante un análisis técnico conocido como *Fingerprinting*. Este proceso de identificación de servicios y sistemas proporciona una comprensión más detallada de la configuración y el entorno del sistema, lo que es fundamental para el análisis de vulnerabilidades y la implementación de medidas de seguridad adecuadas.

4.4.5 Búsqueda y verificación de vulnerabilidades

En esta etapa, se lleva a cabo la búsqueda, identificación y verificación de vulnerabilidades o debilidades en los servidores o en la red en general. El objetivo es detectar posibles agujeros de seguridad y errores de configuración que puedan ser explotados por atacantes. Para realizar esta tarea, se emplean herramientas automáticas diseñadas para escanear sistemas en busca de vulnerabilidades conocidas y evaluar el nivel de parcheo de los sistemas. Sin embargo, es importante tener en cuenta que estas herramientas pueden no detectar nuevas vulnerabilidades que aún no hayan sido incluidas en sus bases de datos. Por lo tanto, también se debe estar al tanto de las vulnerabilidades recientemente publicadas en fuentes confiables, incluso aquellas que aún no han sido incorporadas en las herramientas automáticas de escaneo. Esta búsqueda exhaustiva y constante de vulnerabilidades es esencial para mantener la seguridad de los sistemas y prevenir posibles brechas de seguridad.

4.4.6 Testeo de aplicaciones de internet

En esta fase, se utilizan diversas técnicas de análisis de software para detectar fallos de seguridad en aplicaciones web. Dado que se trata de un análisis externo, se pueden aplicar pruebas de caja negra en este módulo. Las pruebas de caja negra implican evaluar la seguridad de una aplicación sin conocer su estructura interna ni el código fuente. En su lugar, se realizan pruebas desde la perspectiva de un atacante externo, explorando la aplicación y buscando vulnerabilidades sin acceso privilegiado. Este enfoque permite identificar posibles puntos débiles en la aplicación que podrían ser explotados por atacantes externos para comprometer la seguridad del sistema.

4.4.7 Testeo de relaciones de confianza

En esta etapa, se lleva a cabo el testeo de las relaciones de confianza dentro de la red. El enrutamiento, en términos técnicos, está diseñado para garantizar que solo aquellos que hayan sido expresamente autorizados puedan acceder a la red. Esto implica evaluar los mecanismos de enrutamiento y las políticas de acceso para asegurar que sólo los dispositivos y usuarios autorizados puedan comunicarse entre sí dentro de la red. Se busca identificar y corregir posibles vulnerabilidades en las configuraciones de enrutamiento que podrían permitir el acceso no autorizado a la red, lo que podría poner en riesgo la seguridad de la misma.

4.4.8 Verificación de redes inalámbricas

En esta fase, se lleva a cabo la verificación de las redes inalámbricas, centrándose en el estándar 802.11 (*Wi-Fi*). Este estándar establece un método para verificar la seguridad de las redes inalámbricas, que se basa principalmente en la cobertura y el acceso de los puntos de acceso en redes ad hoc. Se examinan los protocolos de seguridad implementados, la configuración de los puntos de acceso y la robustez de las contraseñas utilizadas para proteger el acceso a la red inalámbrica.

Además, se evalúa la detección y prevención de intrusiones en la red *Wi-Fi*, así como la capacidad de resistir ataques como el *sniffing* y la suplantación de identidad. Es fundamental garantizar que las redes inalámbricas estén adecuadamente protegidas para evitar accesos no autorizados y proteger la confidencialidad e integridad de los datos transmitidos a través de ellas.

4.5 Documentación e Informes

Al concluir la detección de vulnerabilidades, es fundamental presentar un informe detallado que documente cada uno de los tests realizados y sus resultados. Este informe debe incluir una **lista exhaustiva de las vulnerabilidades examinadas**, las que fueron detectadas, así como los servicios y dispositivos vulnerables identificados. Además, se debe evaluar el riesgo asociado a cada vulnerabilidad encontrada en los servicios y dispositivos, proporcionando una clasificación del nivel de riesgo para cada una.

Además de los resultados de los tests, el informe debe contener información sobre los programas utilizados durante el análisis, incluyendo detalles sobre las herramientas de detección de vulnerabilidades empleadas y sus configuraciones. Es importante que el **informe sea claro y conciso**, proporcionando una visión completa de la seguridad de la infraestructura analizada y recomendaciones específicas para mitigar las vulnerabilidades identificadas.

4.6 Ciclo de vulnerabilidades

Una vez que se ha logrado detectar las vulnerabilidades hay una serie de pasos para tratar de remediarlas:

4.6.1 Análisis de activos

Este ciclo de remediación comienza con la **identificación y categorización de los activos** de la organización para abordar las vulnerabilidades de manera efectiva. Por ejemplo, mantener un inventario detallado de direcciones IP es fundamental para descubrir qué dispositivos están conectados a la red y cuáles podrían haber pasado desapercibidos.

Además de las direcciones IP, es importante categorizar otros activos, como servidores, dispositivos de red, aplicaciones, bases de datos y otros recursos críticos de información. Esta categorización permite priorizar la corrección de vulnerabilidades según su impacto en los activos y en la seguridad global de la organización.

El análisis de activos no se limita solo a la identificación inicial, sino que también **implica mantener actualizado el inventario** a medida que se agregan o eliminan activos, y revisar regularmente la categorización para garantizar que sea relevante y precisa en todo momento.

4.6.2 Clasificar y priorizar riesgos

Dentro del ciclo de remediación de vulnerabilidades, una etapa crucial consiste en realizar escaneos de sistemas para detectar posibles fallos de seguridad, de acuerdo a las estrategias mencionadas anteriormente

Una vez completado el escaneo, el escáner genera un informe detallado que documenta todas las vulnerabilidades detectadas. Sin embargo, es importante tener en cuenta que es imposible remediar todas las vulnerabilidades detectadas debido a limitaciones de tiempo, recursos humanos y financieros. Por lo tanto, es necesario clasificar y priorizar el riesgo que cada vulnerabilidad representa para la organización.

Para ello, se debe establecer un esquema de prioridad que combine el nivel de severidad de una vulnerabilidad con la importancia del sistema afectado para la empresa. En esta primera instancia, se deben enfocar los esfuerzos en remediar las vulnerabilidades más graves que afecten a sistemas críticos, con el objetivo de reducir el riesgo general de seguridad y proteger los activos más importantes de la organización.

4.6.3 Probar parches y configuraciones

Una vez detectadas las vulnerabilidades en el sistema o inventario, y tras clasificar y priorizar los riesgos asociados a estas vulnerabilidades, el siguiente paso es probar los parches y cambios de configuración necesarios. Sin embargo, este proceso de parcheo puede conllevar riesgos para el sistema de la organización, ya que **los parches de software pueden introducir nuevos errores** aún no detectados.

Es fundamental llevar a cabo el parcheo de forma cuidadosa. Idealmente, los parches deben ser instalados inicialmente en una única máquina para realizar pruebas exhaustivas y verificar si surgen problemas. De esta manera, se evita la propagación de errores en todos los sistemas o dispositivos. Además, es importante tener en cuenta que el software corregido o reparado (parcheado) puede restaurar algunas configuraciones a valores predeterminados, lo que puede requerir ajustes adicionales.

Es crucial descargar los parches únicamente desde sitios oficiales del fabricante del software. El uso de parches obtenidos de fuentes no confiables, como sitios de terceros, puede exponer a la organización a riesgos adicionales, como la introducción de malware o versiones anteriores del software con errores conocidos.

Los informes generados por los escáneres de vulnerabilidades a menudo incluyen instrucciones detalladas sobre cómo proceder con el parcheo o la modificación de la configuración necesaria para mejorar la seguridad del sistema. Estas instrucciones son valiosas para garantizar que los parches se implementen de manera efectiva y se minimice el riesgo de explotación de las vulnerabilidades detectadas.

4.6.4 Aplicar parches y configuraciones

Una vez probados los parches y los cambios de configuración, es crucial aplicarlos de manera efectiva en todos los sistemas de la red. Si se ha verificado que los parches funcionan correctamente en una máquina, es necesario proceder a implementarlos en todas las demás máquinas de la red. Esta tarea puede ser especialmente laboriosa, dependiendo del tamaño y la complejidad de la red. Sin embargo, existen soluciones automáticas de implementación de parches que pueden facilitar este proceso.

Además, algunos escáneres de vulnerabilidades tienen la capacidad de generar tickets automáticamente, los cuales son asignados a ingenieros responsables de llevar a cabo la remediación. Estos tickets permiten dar seguimiento a todo el proceso de aplicación de parches y cambios de configuración, asegurando que ninguna vulnerabilidad identificada quede sin resolver y que se mantenga un registro claro de las acciones tomadas para mejorar la seguridad del sistema.

5. TIPOS DE ANÁLISIS DE VULNERABILIDADES

El modelo de madurez de hacking ético de SCYTHE ofrece a las organizaciones la capacidad de evaluar y mejorar su postura de seguridad mediante el uso de pruebas de penetración éticas. Este enfoque permite a los expertos en seguridad llevar a cabo una serie de evaluaciones contra una organización para identificar vulnerabilidades y debilidades en su infraestructura y políticas de seguridad. Este documento detalla el proceso involucrado en la realización de dichas evaluaciones
y cómo pueden beneficiar a la organización en términos de fortalecimiento de su seguridad cibernética.

Figura 1. Tipos de análisis de vulnerabilidades según el modelo SCYTHE. Fuente: SCYTHE

Para conocer más sobre la ***SCYTHE***, puede acceder al link disponible dentro del aula virtual.

5.1 Escaneo de vulnerabilidades

Escanear una organización en busca de vulnerabilidades mediante un escáner automatizado es una de las evaluaciones más básicas pero esenciales dentro del ámbito del hacking ético. El objetivo principal de esta actividad es **identificar y catalogar las vulnerabilidades** conocidas presentes en los sistemas y aplicaciones objetivo de la organización. Esta fase del proceso de evaluación requiere un esfuerzo mínimo, siempre y cuando se cuente con las herramientas adecuadas.

5.1.1 Análisis de GAP

El análisis de brechas (GAP) es una herramienta en el ámbito de la seguridad informática que permite evaluar el nivel de cumplimiento de una organización en relación con legislaciones específicas, normativas sectoriales o estándares internacionales de seguridad. Además de evaluar el grado de cumplimiento, este análisis también ayuda a identificar las deficiencias y discrepancias entre los requisitos de seguridad establecidos y la implementación actual de medidas de seguridad.

En el contexto de la protección de datos, el análisis de brechas también desempeña un papel crucial al evaluar el riesgo de fuga de información sensible. Este proceso implica identificar las vulnerabilidades y puntos débiles en los sistemas, procesos y políticas de una organización que podrían facilitar la filtración o pérdida de información confidencial.

Al realizar un análisis de brechas, se pueden identificar áreas de mejora y establecer un plan de acción para cerrar las brechas de seguridad existentes, fortaleciendo así la postura de seguridad de la organización y mitigando los riesgos asociados a la exposición de datos sensibles.

5.2 Evaluación de Vulnerabilidades

La evaluación de vulnerabilidades implica realizar análisis exhaustivos sobre los sistemas y servicios disponibles con el fin de identificar vulnerabilidades conocidas. Una vulnerabilidad se define como cualquier error que permite realizar acciones no autorizadas en un sistema. Estas acciones pueden incluir la interrupción del servicio, acceso no autorizado a información o funciones, escalada de privilegios, o incluso la ejecución de código en el sistema, entre otros.

En otras palabras, la existencia de una vulnerabilidad en una aplicación o sistema puede ser aprovechada por un atacante, ya sea con intenciones maliciosas o no, para comprometer la seguridad de la información de una empresa, impactando en la disponibilidad, integridad o confidencialidad de los datos.

Las vulnerabilidades en las aplicaciones suelen residir en su código fuente, como resultado de errores u omisiones durante el proceso de desarrollo. Por otro lado, las vulnerabilidades en los sistemas pueden estar relacionadas con configuraciones inseguras, como el uso de contraseñas predeterminadas.

El propósito fundamental de una evaluación de vulnerabilidades es identificar las debilidades presentes en los sistemas de una organización para elaborar un plan de acción adecuado que permita mitigar los riesgos asociados.

5.2.1 Aspectos involucrados en una Evaluación de Vulnerabilidades

Este tipo de evaluación puede llevarse a cabo de dos maneras: interna y externa. La evaluación interna se realiza desde dentro de la organización, permitiendo detectar vulnerabilidades en los sistemas y recursos desde una perspectiva interna. Por otro lado, la evaluación externa simula el enfoque de un atacante externo, evaluando la seguridad perimetral de la organización desde fuera de sus fronteras.

En resumen, una evaluación de vulnerabilidades implica las siguientes etapas:

- **Identificación temprana de debilidades y vulnerabilidades**, antes de que puedan ser explotadas por un atacante.
- **Mapeo de las superficies de ataque** para evaluar planes de acción y respuesta.
- **Descubrimiento de vulnerabilidades** mediante la modificación de configuraciones específicas.
- **Visualización de la infraestructura** de la organización desde la perspectiva de un atacante

5.3 Pruebas de penetración

El *Penetration Testing*, o prueba de penetración, representa un paso adelante en comparación con la evaluación de vulnerabilidades, ya que **no se limita a identificar las vulnerabilidades, sino que también las explota**. Esta práctica se lleva a cabo de manera profesional y controlada, utilizando un alcance y reglas de compromiso cuidadosamente definidos.

Durante las pruebas de penetración, se realizan una serie de pruebas ofensivas contra los mecanismos de defensa existentes en el entorno analizado. Estas pruebas abarcan desde el análisis de dispositivos físicos y digitales hasta la evaluación del factor humano mediante la **Ingeniería Social**.

El objetivo principal de estas pruebas es verificar cómo responden los mecanismos de defensa en situaciones extremas, con el fin de detectar vulnerabilidades y deficiencias en los mismos. Además, se busca **identificar las brechas y deficiencias en los controles de seguridad** que podrían comprometer la seguridad de la información crítica de la organización.

Realizar pruebas de penetración es esencial porque ayuda a prevenir incidentes de seguridad que podrían haberse evitado si los mecanismos de protección hubieran sido fortalecidos a tiempo. Estos incidentes incluyen fugas de información, accesos no autorizados, pérdida de datos, entre otros.

Las actividades de un **Penetration Test** incluyen múltiples fases y tipos de pruebas en diversos ámbitos y entornos. La profundidad de estas actividades depende de varios factores, como el nivel de riesgo que representa para el cliente y las necesidades específicas de seguridad de la organización.

5.3.1 Fase de reconocimiento

La fase de reconocimiento, también conocida como fase de recolección de información, es una de las etapas fundamentales en un proceso de auditoría de seguridad. Esta fase **puede ser una de las más prolongadas**, ya que implica definir objetivos y recopilar información exhaustiva que será utilizada en las etapas posteriores del proceso.

Durante la fase de reconocimiento, se busca **obtener una amplia gama de información sobre la organización objetivo**. Esto incluye desde los nombres y direcciones de correo electrónico de los empleados hasta detalles sobre la topología de la red, direcciones IP, infraestructura tecnológica, sistemas operativos utilizados, servicios en línea, entre otros aspectos relevantes.

Es importante destacar que la cantidad y profundidad de la información recopilada dependerá de los objetivos específicos establecidos para la auditoría. Por lo tanto, es crucial definir claramente los objetivos y alcances del proceso de reconocimiento antes de iniciar cualquier actividad de recopilación de datos.

5.3.2 Fase de escaneo

En la fase de escaneo, se aprovecha la información recopilada durante la fase de reconocimiento para identificar posibles puntos de entrada o vulnerabilidades en los sistemas de la organización objetivo. Esta etapa implica llevar a cabo un **escaneo exhaustivo de los puertos y servicios disponibles en la red**.

El escaneo de puertos y servicios permite identificar qué servicios están activos en los diferentes sistemas y qué puertos están abiertos y disponibles para la comunicación. Esta información es crucial para comprender la topología de la red y determinar posibles puntos de vulnerabilidad que podrían ser explotados por un atacante.

Una vez completado el escaneo de puertos y servicios, se procede al escaneo de vulnerabilidades. Esta fase implica el uso de herramientas especializadas para identificar posibles fallos de seguridad o vulnerabilidades en los sistemas y aplicaciones. La detección de estas vulnerabilidades ayuda a definir los vectores de ataque potenciales que podrían ser utilizados para comprometer la seguridad de la organización.

5.3.3 Fase de enumeración

En la fase de enumeración, se busca obtener información adicional sobre los sistemas y servicios identificados durante las fases anteriores del proceso de evaluación de seguridad. El propósito principal es **recopilar datos específicos** relacionados con usuarios, nombres de equipos, servicios de red y otros detalles relevantes que puedan ser útiles para planificar y ejecutar posibles ataques.

Durante esta etapa, se establecen conexiones activas con los sistemas objetivo y se ejecutan consultas para recopilar información detallada sobre la configuración, usuarios activos, grupos de seguridad, políticas de acceso y otros aspectos importantes de la infraestructura de TI de la organización.

La enumeración es crucial para obtener una comprensión más profunda de la red y sus activos, lo que permite a los evaluadores de seguridad identificar posibles puntos débiles o áreas de exposición que podrían ser aprovechadas por un atacante. Esta información recopilada durante la fase de enumeración proporciona una base sólida para la siguiente etapa del proceso de evaluación, que involucra la explotación de vulnerabilidades y la prueba de seguridad de los sistemas.

5.3.4 Fase de acceso

En la fase de acceso, **se aprovechan las vulnerabilidades** previamente identificadas para comprometer el sistema objetivo. Esta etapa implica la explotación activa de las debilidades descubiertas durante el proceso de evaluación para obtener acceso no autorizado al sistema.

Una vez que se ha identificado una vulnerabilidad y se ha confirmado su explotabilidad, el auditor procede a utilizarla para ingresar al sistema objetivo. Esto puede implicar el uso de técnicas de hacking para sortear medidas de seguridad y obtener acceso a recursos sensibles o áreas restringidas del sistema.

El objetivo es **simular un ataque real** y demostrar cómo un adversario potencial podría explotar las vulnerabilidades para acceder ilegalmente al sistema, lo que ayuda a la organización a identificar y corregir las deficiencias de seguridad antes de que sean aprovechadas por amenazas reales.

5.3.5 Fase de mantenimiento de acceso

En la fase de mantenimiento de acceso, una vez que se ha logrado acceder al sistema objetivo, se busca **establecer mecanismos para mantener ese acceso de manera prolongada y discreta**. El objetivo principal es asegurar que el sistema comprometido permanezca accesible para el atacante durante el mayor tiempo posible, lo que le permite continuar explorando y explotando sus vulnerabilidades.

Esta fase implica la instalación de *backdoors*, la creación de cuentas de usuario adicionales, la modificación de permisos de acceso y otras técnicas destinadas a garantizar la persistencia del acceso sin ser detectado por los sistemas de seguridad de la organización.

Además, es crucial señalar que, una vez completado el proceso de penetración, se genera documentación detallada que resume los hallazgos y las acciones realizadas durante la auditoría. Esta documentación proporciona al cliente una visión clara de las vulnerabilidades identificadas, las brechas de seguridad y las recomendaciones para mejorar la postura de seguridad de la organización.

5.4 Ejercicios de Red Team

El *Red Team* se enfoca en **evaluar personas, procesos y tecnologías** de una organización, emulando las tácticas de los adversarios para probar de manera integral su postura de seguridad. Los principales clientes del *Red Team* son los defensores, aquellos responsables de los controles de detección y alerta.

Los ejercicios de *Red Teaming* buscan **identificar vulnerabilidades y brechas de seguridad en el sistema simulando un ciberataque**. Esto permite a la organización comprender sus debilidades y fortalezas en la defensa contra amenazas cibernéticas reales.

Durante un ejercicio de *Red Team*, se llevan a cabo varias etapas que abarcan desde el establecimiento de objetivos hasta la emisión de informes detallados sobre las vulnerabilidades descubiertas. Estas etapas incluyen el reconocimiento del objetivo, la explotación de vulnerabilidades, la escalada de privilegios y la generación de inteligencia sobre posibles amenazas.

Es importante destacar que el *Red Teaming* va más allá de las pruebas de penetración tradicionales. Mientras que estas últimas se centran en explotar vulnerabilidades específicas del sistema, el *Red Teaming* **simula una amenaza persistente avanzada**, evaluando la resistencia de la organización ante ataques complejos y multifacéticos.

Además, el *Red Teaming* se diferencia de las pruebas de penetración en varios aspectos clave. Por ejemplo, solo la alta dirección de la organización sabe que se está llevando a cabo un ejercicio de *Red Team*, mientras que el equipo de IT no está informado para simular una situación lo más cercana posible a un escenario real de ataque. Además, el *Red Teaming*

emplea una variedad de técnicas, como la ingeniería social y la evaluación de la seguridad física, que no se utilizan en las pruebas de penetración tradicionales.

5.5 Ejercicios de Purple Team

El *Purple Team* es una práctica en seguridad informática que involucra la colaboración entre el equipo ofensivo (*Red Team)* y el equipo defensivo (*Blue Team)*. En un ejercicio de *Purple Team*, ambos equipos trabajan juntos de manera virtual, con una comunicación abierta y transparente sobre cada fase del ataque y las medidas de defensa implementadas. Esta colaboración permite una **mejora continua de las capacidades de detección, respuesta y mitigación** de la organización en tiempo real.

Durante un ejercicio de *Purple Team*, el equipo *Red Team* lleva a cabo una serie de ataques simulados, mientras que el equipo *Blue Team* monitorea y responde a estas acciones. A medida que se desarrolla el ejercicio, se facilita una discusión abierta entre ambos equipos, donde se comparten técnicas de ataque, estrategias de defensa y se analizan las lecciones aprendidas. Esto permite identificar y abordar debilidades en los procesos, la tecnología y la capacitación del personal de seguridad.

La colaboración entre el equipo *Red Team* y el equipo *Blue Team* en un ejercicio de *Purple Team* ayuda a mejorar la postura de seguridad de la organización de manera integral, al tiempo que fortalece la coordinación y la comunicación entre los equipos de seguridad. Además, proporciona una oportunidad única para probar y mejorar la efectividad de las políticas, procedimientos y herramientas de seguridad en un entorno controlado y colaborativo.

5.6 Emulaciones de adversarios

La emulación de adversarios es una modalidad de compromiso en el ámbito del *hacking* ético en la que un equipo *Red Team simula las tácticas y procedimientos de un atacante real* contra una organización. A diferencia de los ataques genéricos, este tipo de compromisos **se basan en inteligencia para identificar a los adversarios** con la intención, oportunidad y capacidad de realizar ataques específicos.

En un ejercicio de emulación de adversarios, se recrea un escenario basado en la metodología o marco de trabajo del atacante, el cual es ejecutado por el equipo *Red Team* en la organización objetivo. El objetivo principal es evaluar si la organización posee la capacidad de detectar, responder y mitigar un ataque de manera efectiva. Estos ataques están diseñados para ser realistas, utilizando las mismas tácticas, técnicas y procedimientos empleados por adversarios sofisticados que realizan ataques dirigidos.

Este tipo de ejercicios no se limita únicamente a evaluar los aspectos tecnológicos de la seguridad y sus controles preventivos, sino que también **busca mejorar la madurez de los procesos y roles de seguridad** dentro de la organización. Esto incluye roles como analistas de

seguridad, respondientes a incidentes, cazadores de amenazas, el CISO, administradores de sistemas, entre otros.

6. OWASP

El Proyecto Abierto de Seguridad de Aplicaciones Web, o **OWASP**, es una organización internacional sin fines de lucro dedicada a la seguridad de las aplicaciones web. Uno de los principios fundamentales del OWASP es que todos sus materiales se encuentran disponibles de forma gratuita y son fácilmente accesibles en su sitio web, lo cual posibilita que cualquiera pueda mejorar la seguridad de su propia aplicación web. Entre los materiales que ofrecen se incluyen documentación, herramientas, vídeos y foros.

Quizá su proyecto más conocido sea el OWASP Top 10, un informe que se actualiza con regularidad y en el que se exponen los problemas de seguridad de las aplicaciones web, centrándose en los 10 riesgos más importantes. El informe lo elabora un equipo de expertos en seguridad de todo el mundo. El OWASP hace referencia al Top 10 como un "documento de concienciación", y recomienda que todas las empresas incorporen el informe a sus procesos para minimizar o mitigar los riesgos de seguridad.

Para conocer más sobre la ***OWASP Top 10***, puede acceder al link disponible dentro del aula virtual.

6.1 OWASP TOP 10 DE 2021

A continuación, se muestran los riesgos de seguridad recogidos en el informe OWASP Top 10 de 2021

6.1.1 Pérdida de control de acceso

El control de acceso hace referencia a un sistema que controla el acceso a la información o a la funcionalidad. Los controles de acceso que no funcionan permiten a los atacantes saltarse la autorización y realizar tareas como si fueran usuarios privilegiados, como los administradores. Por ejemplo, una aplicación web podría permitir que un usuario cambiara la cuenta con la que ha iniciado sesión con solo cambiar parte de una URL, sin ninguna otra verificación.

Los controles de acceso pueden asegurarse con una aplicación web utilice tokens de autorización y establezca controles estrictos sobre los mismos.

6.1.2 Fallas criptográficas

Si las aplicaciones web no protegen los datos confidenciales, como la información financiera y las contraseñas, los atacantes pueden acceder a esos datos y venderlos o utilizarlos con fines maliciosos. Un método popular para robar información confidencial es el uso de un ataque en ruta.

El riesgo de exposición de datos puede minimizarse al encriptar todos los datos confidenciales, y al desactivar el almacenamiento en caché de cualquier información confidencial. Además, los desarrolladores de aplicaciones web deben asegurarse de que no están almacenando innecesariamente ningún dato confidencial.

6.1.3 Inyección

Los ataques de inyección ocurren cuando se envían datos que no son de confianza a un intérprete de código a través de la entrada de un formulario o algún otro envío de datos a una aplicación web. Por ejemplo, un atacante podría introducir código de base de datos SQL en un formulario que espera un nombre de usuario en texto plano. Si la entrada del formulario no está asegurada de forma adecuada, se acabaría ejecutando el código SQL. Esto se conoce como un ataque de inyección de código SQL.

Los ataques de inyección pueden evitarse al validar o sanear los datos enviados por el usuario. La validación significa rechazar los datos que tienen un aspecto sospechoso, mientras que la sanitización hace referencia a la limpieza de las partes de aspecto sospechoso de los datos. Además, el administrador de la base de datos puede establecer controles para minimizar la cantidad de información que puede sacar a la luz un ataque de inyección.

6.1.4 Diseño Inseguro

Es una nueva categoría introducida en la edición 2021, con un enfoque en los riesgos relacionados con fallas de diseño. Si realmente se quiere madurar como industria, es necesario "mover a la izquierda" del proceso de desarrollo las actividades de seguridad. Se precisan más modelos de amenazas, patrones y principios con diseños seguros y arquitecturas de referencia. Un diseño inseguro no puede ser corregido con una implementación perfecta debido a que, por definición, los controles de seguridad necesarios nunca se crearon para defenderse de ataques específicos.

6.1.5 Configuración de seguridad incorrecta

La desconfiguración de la seguridad es la vulnerabilidad más común de la lista, y suele ser el resultado de usar configuraciones por defecto o de mostrar errores excesivamente detallados. Por ejemplo, una aplicación podría mostrar al usuario errores demasiado descriptivos que mostraran vulnerabilidades en la aplicación. Esto se puede mitigar mediante la eliminación de cualquier función no utilizada en el código y al asegurarse de que los mensajes de error sean más generales.

6.1.6 Componentes vulnerables y desactualizados

Muchos desarrolladores web modernos utilizan componentes como bibliotecas y marcos en sus aplicaciones web. Estos componentes son piezas de software que ayudan a los desarrolladores a evitar el trabajo redundante y a ofrecer la funcionalidad necesaria. Un ejemplo común son los marcos frontales como React y las bibliotecas más pequeñas que se utilizan para añadir iconos compartidos o pruebas a/b. Algunos atacantes buscan vulnerabilidades en estos componentes que luego pueden utilizar para orquestar ataques. Algunos de los componentes más famosos se utilizan en cientos de miles de sitios web; un atacante que encuentre un agujero de seguridad en uno de estos componentes podría dejar cientos de miles de sitios vulnerables.

Los desarrolladores de componentes suelen ofrecer parches de seguridad y actualizaciones para tapar las vulnerabilidades conocidas, pero los desarrolladores de aplicaciones web no siempre tienen las versiones parcheadas o más recientes de los componentes que se ejecutan en sus aplicaciones. Para minimizar el riesgo de ejecutar componentes con vulnerabilidades conocidas, los desarrolladores deben eliminar de sus proyectos los componentes que no utilicen, así como asegurarse de que reciben componentes de una fuente de confianza y de que estos estén actualizados.

6.1.7 Fallas de identificación y autenticación

Las vulnerabilidades en los sistemas de autenticación (login) pueden dar acceso a los atacantes a las cuentas de los usuarios e incluso la capacidad de poner en riesgo todo un sistema mediante el uso de una cuenta de administrador. Por ejemplo, un atacante puede tomar una lista con miles de combinaciones conocidas de nombres de usuarios y contraseñas conseguidas durante una fuga de datos, y utilizar un script para probar todas esas combinaciones en un sistema de inicio de sesión para ver si funciona alguna.

Algunas estrategias para mitigar las vulnerabilidades de autenticación son pedir la autenticación en dos fases (2FA), así como limitar o retrasar los intentos repetidos de inicio de sesión mediante el uso de la limitación de velocidad.

6.1.8 Fallas en el Software y en la Integridad de los Datos

Ésta es una nueva categoría para la edición 2021, que se centra en hacer suposiciones relacionadas con actualizaciones de software, los datos críticos y los pipelines CI/CD sin verificación de integridad. Corresponde a uno de los mayores impactos según los sistemas de ponderación de vulnerabilidades (CVE/CVSS, siglas en inglés para Common Vulnerability and Exposures/Common Vulnerability Scoring System).

6.1.9 Fallas en el Registro y Monitoreo

Muchas aplicaciones web no toman suficientes medidas para detectar las fugas de datos. Se suele tardar unos 200 días promedio en detectar una fuga después de que esta se haya producido. Esto brinda mucho tiempo a los atacantes para causar daños antes de que haya una respuesta. OWASP recomienda que los desarrolladores web implementen planes de registro y supervisión, así como de respuesta a incidentes, para asegurarse de que están al tanto de los ataques a sus aplicaciones.

6.1.10 Falsificación de Solicitudes del Lado del Servidor (SSRF)

Las fallas de SSRF ocurren cuando una aplicación web está obteniendo un recurso remoto sin validar la URL proporcionada por el usuario. Permite que un atacante coaccione a la aplicación para que envíe una solicitud falsificada a un destino inesperado, incluso cuando está protegido por un firewall, VPN u otro tipo de lista de control de acceso a la red (ACL).

Dado que las aplicaciones web modernas brindan funciones convenientes a los usuarios finales, la búsqueda de una URL se convierte en un escenario común. Como resultado, la incidencia de SSRF está aumentando. Además, la gravedad de SSRF es cada vez mayor debido a los servicios en la nube y la complejidad de las arquitecturas.

La seguridad de la información en la empresa tiene tres aspectos fundamentales: las tecnologías, la educación y la gestión. Mientras que las tecnologías siempre estuvieron ligadas a la seguridad, o al menos de forma intuitiva para el usuario (es fácil asociar un antivirus, un firewall o una contraseña a la seguridad), también hace muchos años se insiste con la importancia de la educación en seguridad, dada la cantidad de amenazas informáticas basadas en la Ingeniería Social. Asociar la seguridad de la información a la gestión es un concepto indispensable y los especialistas en seguridad de la información están pidiendo mayor foco en este aspecto para una eficiente protección en entornos corporativos.

7. OSINT: INTELIGENCIA DE FUENTES ABIERTAS

La inteligencia de código abierto, conocida como OSINT (*Open Source Intelligence*), consiste en la **recopilación, análisis y utilización de información pública** disponible en diversas fuentes en línea para obtener conocimientos valiosos sobre personas, organizaciones, eventos o cualquier otro aspecto relevante. En este contexto, el OSINT desempeña un papel crucial al proporcionar datos que pueden ser utilizados para evaluar riesgos, prevenir amenazas, realizar investigaciones forenses y tomar decisiones informadas en diferentes áreas, desde la ciberseguridad hasta la inteligencia empresarial.

7.1 Investigación defensiva

La investigación defensiva en el ámbito de la seguridad informática es una práctica fundamental que complementa el enfoque tradicional de OSINT.

La investigación defensiva se centra en **entender qué datos personales y qué tipo de información sobre nosotros mismos están disponibles en la web**. Este enfoque nos permite anticipar qué detalles podrían ser recopilados por un investigador externo, como parte de un análisis similar al que se enseña en este curso de seguridad.

Además de brindarnos una visión integral de nuestra exposición en línea, la investigación defensiva nos ayuda a mitigar potenciales riesgos de seguridad, como el robo de información o la suplantación de identidad.

7.2 Conceptos básicos

Empecemos por establecer algunos conceptos fundamentales que serán recurrentes. Cuando nos referimos a un **dato**, hablamos de cualquier información relacionada con la persona que estamos investigando. Esto puede abarcar una amplia gama de contenidos, como fotografías, textos, grabaciones, historiales de navegación, entre otros.

Estos datos suelen ser recopilados por empresas o sistemas automatizados en grandes cantidades, provenientes de diversas fuentes y con la capacidad de ser procesados a alta velocidad; a esta recopilación masiva de datos se le conoce como *Big Data*.

Por otro lado, los **metadatos** son piezas de información asociadas a otros datos, como fotografías, de las cuales se pueden extraer detalles como la fecha y hora de captura, e incluso la ubicación del dispositivo en el momento de la captura. Entender estos conceptos nos

proporciona una base sólida para adentrarnos en el mundo del OSINT y comprender cómo se recopila y analiza la información en línea.

7.3 Por qué usar OSINT

OSINT, es un conjunto de técnicas y herramientas diseñadas para recopilar, correlacionar y procesar información de fuentes públicas. Se centra en **aplicar análisis e inteligencia a la vasta cantidad de datos disponibles en Internet**, con el propósito de extraer conclusiones útiles para diversas actividades como investigaciones, monitoreo, análisis de mercado, entre otros.

¿Por qué elegir OSINT sobre otros métodos de investigación? La mayoría de las personas utilizan servicios en línea donde comparten fotos personales, opiniones políticas, intereses, y más. Sin embargo, no todos son conscientes de que esta información puede estar accesible al público y ser utilizada por individuos u organizaciones con diversos objetivos, desde planificar un ataque hasta resolver un crimen. Es por ello que las técnicas y herramientas de OSINT están en constante evolución, convirtiéndose en un elemento fundamental en la seguridad de la información y en la gestión de riesgos digitales.

7.4 Aplicación en ciberseguridad

Si bien OSINT se conecta intrínsecamente con la ciberseguridad, sus aplicaciones son diversas y fundamentales en diversas áreas. En primer lugar, las investigaciones privadas utilizan OSINT para obtener información sobre individuos relacionados con el investigador, ya sea por motivos personales o profesionales, como la sospecha de su participación en ciberataques.

Por otro lado, las investigaciones públicas, llevadas a cabo por entidades policiales o gubernamentales, tienen como objetivo principal recabar datos verificados para casos legales, como delitos cibernéticos o personas desaparecidas.

En el ámbito de la ciberseguridad, los profesionales pueden realizar investigaciones OSINT sobre los objetivos de ejercicios de penetración en empresas, lo que les **permite conocer mejor a su objetivo y encontrar posibles puntos de vulnerabilidad**, como a través de ataques de ingeniería social. Estas aplicaciones de OSINT son cruciales para la detección, prevención y mitigación de amenazas en el ciberespacio.

7.5 OSINT ¿Legal o Ilegal?

Una de las cuestiones que genera más dudas en torno a OSINT es su legalidad, especialmente porque aparentemente no existen límites en cuanto a la información que se puede obtener. Sin embargo, es importante recordar que **OSINT se basa en la recopilación de datos de fuentes públicas o abiertas**, lo que inicialmente protege al investigador de acusaciones de robo de información.

La recopilación y análisis de información pública es legal en sí misma, siempre y cuando los datos provengan de fuentes accesibles para cualquier persona. No obstante, la divulgación de información sensible con intenciones dañinas constituye un delito, conocido como **doxxing**, y está tipificado en la legislación de la mayoría de los países. Por esta razón, es crucial consultar y

tener en cuenta la legislación del país donde se lleva a cabo la investigación, y actuar en conformidad con ella en todas las acciones realizadas.

7.6 Ciclo OSINT

Las fases de una investigación OSINT pueden visualizarse como un ciclo que comprende las siguientes etapas:

- **Planteamiento de requisitos**: En esta fase, se busca definir de manera formal los objetivos de la investigación y su estructura. Se establece el formato requerido para la información, el nivel de formalidad y la veracidad de las fuentes aceptadas, entre otros aspectos.
- **Identificación de fuentes**: Durante esta etapa, se enumeran todas las posibles fuentes de información para iniciar la investigación, considerando la cantidad de información disponible inicialmente. Es importante destacar que esta lista puede no ser exhaustiva, ya que nuevas fuentes pueden ser descubiertas durante las siguientes fases.
- **Adquisición y procesamiento de la información**: Aquí se procede a recopilar y analizar la información obtenida de las fuentes identificadas en la fase anterior. Durante el procesamiento, es posible obtener nueva información, como la extracción de metadatos de una imagen, lo que puede conducir a revisar nuevamente la identificación de fuentes.
- **Presentación y formalización de los resultados**: La información cruda recopilada durante la investigación carece de utilidad si no se presenta de manera adecuada. Por lo tanto, en esta etapa se realiza la presentación de los resultados de manera estructurada y conforme a los requisitos establecidos en la fase inicial.

7.7 Obtención de la información

Entender qué estamos buscando y la medida de rigurosidad con la que debemos trabajar son aspectos críticos que pueden optimizar significativamente nuestra investigación, evitando pérdidas de tiempo y errores.

Si nuestro objetivo es encontrar una información específica en lugar de datos generales, como la apariencia física de una persona, es recomendable dirigir nuestras fuentes hacia aquellas que puedan proporcionar la información deseada, como las redes sociales que suelen contener fotografías. No obstante, si carecemos de datos suficientes para acceder directamente a lo que buscamos (por ejemplo, un nombre de usuario), es importante considerar también las fuentes que nos pueden llevar a este dato, como los motores de búsqueda convencionales.

Cuando la información obtenida se utilizará en un contexto legal, es esencial tener en cuenta que las pruebas provenientes de fuentes poco confiables probablemente no sean admitidas, por lo que es necesario descartarlas y asegurarse de respaldar cualquier hallazgo con varias fuentes de confianza adecuada.

7.7.1 Tipos de fuentes de información

Las fuentes de información utilizadas en **OSINT** pueden ser categorizadas en cuatro grandes grupos. En primer lugar, están las redes sociales, como **Instagram**, **Facebook** o **Twitter**, y los foros de Internet menos conocidos, que suelen contener una gran cantidad de información personal, como fotografías, nombres completos, conexiones personales y laborales, y opiniones. A menudo, esta información está disponible públicamente y puede ser accedida a través de un navegador web.

En segundo lugar, está la **internet profunda**, donde encontramos sitios de redes no accesibles mediante navegadores convencionales, así como aquellos con direcciones finalizadas en *.onion*, además de cuentas privadas. Acceder a este tipo de contenido puede ser más complicado, ya que en el primer caso se requiere un enlace específico para acceder, y en el segundo, el acceso depende de la aceptación del investigador por parte del objetivo, mediante la aprobación de solicitudes de seguimiento o amistad.

Otra fuente de información, más difícil de acceder, es la **literatura gris**, que incluye publicaciones y noticias no difundidas de manera convencional. Estas publicaciones suelen ser de tiradas limitadas, carecen de publicidad y es posible que no sean archivadas. Aunque esta fuente puede contener información relevante, su veracidad puede variar debido a su perfil bajo.

Por último, tenemos los **contenidos derivados de los medios tradicionales**, como programas de televisión, radio, cine y periódicos. Estos suelen ser fáciles de encontrar en los archivos de las imprentas o canales de televisión y, dependiendo de la fuente, pueden considerarse bastante confiables.

7.7.2 Obtención de información

No solo es crucial contar con diversas fuentes de información, sino también emplear métodos adecuados para obtener datos de esas fuentes. Podemos clasificar las formas de obtener información según nuestra interacción con el objetivo.

En primer lugar, está la **obtención activa**, donde el investigador establece contacto directo con el objetivo. Esto puede implicar enviar una solicitud de amistad, realizar un escaneo de red o entablar una conversación utilizando una cuenta anónima. Este enfoque busca obtener información directa de la persona, lo que puede resultar altamente veraz y valioso. Sin embargo, aumenta el riesgo de que el objetivo se dé cuenta de que está siendo investigado, lo cual podría ser contraproducente.

En contraste, encontramos la obtención de **información pasiva**, donde se evita cualquier contacto directo con el objetivo. Aquí se recurre a buscadores en línea, se analizan archivos de medios tradicionales y se examinan perfiles públicos, entre otras técnicas. Aunque la veracidad de esta información depende de la fuente y puede ser menos valiosa, las posibilidades de que el objetivo detecte la investigación son prácticamente nulas.

Es mediante la combinación de estos enfoques que los investigadores pueden obtener la diversidad de información necesaria para sus análisis.

7.7.3 Herramientas de búsqueda: Dorks en buscadores

Los motores de búsqueda tradicionales como *Google, Bing, DuckDuckGo* o *Yandex* son herramientas imprescindibles para llevar a cabo investigaciones de tipo OSINT, ya que recopilan información de una gran parte de Internet. Estas plataformas también ofrecen un conjunto de operadores de búsqueda que permiten filtrar y precisar los resultados según nuestras necesidades. La sintaxis de estas reglas suele ser consistente en la mayoría de los motores de búsqueda, siguiendo un formato heredado de Google.

Si bien comúnmente asociamos OSINT con la investigación dirigida por un solicitante hacia un **objetivo**, también existe la práctica de investigarnos a nosotros mismos, conocida como investigación defensiva. El propósito de esta investigación es conocer qué información personal está disponible en la web y entender qué podría recopilar un investigador si fuéramos el objetivo de un análisis similar al descrito en este curso.

Además de ofrecernos una visión de nuestra huella digital, la investigación defensiva puede ayudarnos a prevenir posibles ataques que se aprovechen de la exposición de información o credenciales. A diferencia de una investigación OSINT convencional, la investigación defensiva parte de una ventaja inicial: el conocimiento de datos como nombres de usuario, correos electrónicos y nombres completos. Esta información facilita la búsqueda del objetivo (nosotros mismos) en sitios como filtraciones de datos o motores de búsqueda de personas.

ACTIVIDAD 1

Le pedimos que realice la Actividad que le proponemos en el campus de manera de ir afianzando conceptos vistos hasta aquí.

ACTIVIDAD 2 (Tarea)

Le pedimos que realice la Actividad que le proponemos en el campus y la envíe al tutor para su corrección.

ACTIVIDAD 3 (Foro)

Le pedimos que a continuación participe del Foro que le proponemos e intercambie reflexiones con sus compañeros.

Antes de continuar con la lectura de la unidad 3 y para poner en práctica los conceptos y procedimientos aprendidos en la presente unidad, le invitamos a realizar la autoevaluación integradora de la unidad 4

SÍNTESIS DE LA UNIDAD

Esta unidad proporciona una visión completa y detallada sobre los principales aspectos de la Seguridad Ofensiva. Comienza explorando los distintos tipos de vulnerabilidades, abordando tanto aquellas de naturaleza física como lógica, lo que permite comprender la diversidad de riesgos a los que pueden estar expuestos los sistemas y redes informáticas. Además, se adentra en los estándares utilizados para evaluar y clasificar estas vulnerabilidades, como CVE, CWE y CAPEC, lo que proporciona un marco de referencia sólido para su identificación y gestión.

Posteriormente, se centra en la detección de vulnerabilidades, destacando las herramientas y técnicas disponibles para llevar a cabo este proceso de forma eficaz. Se exploran las diferentes metodologías de prueba de seguridad, así como la importancia de establecer reglas claras y recopilar información relevante para su análisis. Se abordan también los distintos tipos de pruebas, tanto internas como externas, y se detalla el ciclo de vida de las vulnerabilidades, desde su análisis y clasificación hasta la aplicación de parches y configuraciones para su mitigación.

En una sección posterior, se examinan los diferentes enfoques de análisis de vulnerabilidades, como el escaneo, la evaluación y las pruebas de penetración, detallando las fases y procesos involucrados en cada uno de ellos. Además, se introduce el concepto de OWASP y se analizan sus diez principales vulnerabilidades, lo que brinda una comprensión más profunda de las amenazas más comunes en el panorama de la seguridad informática.

Finalmente, el contenido presenta el concepto de OSINT (Inteligencia de Fuentes Abiertas) y explora su aplicación en el ámbito de la ciberseguridad. Se discute su importancia, legalidad y ciclo de funcionamiento, así como las estrategias y herramientas utilizadas para obtener información de fuentes abiertas de manera efectiva y ética, incluyendo el uso de *dorks* en buscadores como una técnica específica para mejorar la eficiencia de la recopilación de datos. En conjunto, el temario proporciona una visión integral y práctica del análisis de vulnerabilidades en el contexto de la seguridad informática.